CSE487 Cybersecurity, Law and Ethics

Mini Projects Description

Marks distribution for the Mini Projects

Mini Project	Teaching-Learning Method	CO	Mark of Cognitive Learning Level		Mark of Psychomotor Learning Levels		Mark of Affective Learning Level			CO Mark	EP/EA Mapping
			C3	C4	P2	P4	A2	A3	A4		
Project: Securing a networked system with PKI and configure Firewall and IDS	Group-based moderately complex security systems design project with report writing and oral presentation	CO2	1	1	3					5	EP1, EP2, EP4, EP5, EP6
		CO5			2		3			5	EP1, EP2, EP5, EP6 EA1, EA2, EA3, EA4, EA5
		CO6				2			3	5	EP1, EP2, EP5, EP6
Activity: Criticism and design of Terms of Service (ToS), End User License Agreement (EULA), Privacy Policy fulfilling the legal requirements	Case studies with group debate and report writing	CO3	2				3			5	EP4, EP5, EP6
		CO5			2		3			5	EP1, EP2, EP5, EP6 EA1, EA2, EA3, EA4, EA5
		CO6				2			3	5	EP1, EP2, EP5, EP6

Activity: Criticism and justification of actions/stance as per ethical frameworks	Case studies with group debate and report writing	CO4	2					3			EP1, EP4, EP5, EP6
		CO5			2		3			5	EP1, EP2, EP5, EP6 EA1, EA2, EA3, EA4, EA5
		CO6				2			3	5	EP1, EP2, EP5, EP6

Mini Project-1: Securing a networked system with Public Key Infrastructure
Implementing Transport Layer Security on HTTP for https:// connection
Project: Securing a networked system with PKI
Activity: Moderately complex security systems design project with report writing and oral presentation

Details:
You are to preconfigure at least two virtual machines (preferably with Oracle Virtualbox) and configure file sharing, host-only networking and NAT, with a shared folder called "vmshared" hosted at c:\vmshared on the Host computer and /mnt/vmshared on the guest Virtual Machines (VM).

You are to create a full-fledged Certification Authority (CA) called "Acme CA" with web interfaces to issue certificates. From the web interface, a domain owner can issue SSL certificates for him by pasting the CSR in the web interface. Host the web interface in your local machine with www.acmeca.com and the application for the SSL certificate page should be hosted at apply.acmeca.com with HTTPS connection.

Preconfigure the functionality of the web interface for CA by implementing HTTPS for the given domains *.ewubd.edu by issuing a wildcard SSL certificate.

The webserver and the certification authority can be hosted on the same server with the same IP address.

Preconfigure DNS service on the server to resolve the given domain names by creating forward and reverse zone files.

The web server should be hardened after default installation. That means installation and configuration of SSH access to a non-standard port, configuring firewall, configuring IDS, running the apache2 process (httpd service) under a different user with no login, etc.

Preconfigure a monitoring system at the webserver by starting a wireshark capture to detect phishing attacks, and intrusion detection system to detect TCP SYN Flood attacks.

Preconfigure web pages for a phishing attack on freewifi.ewubd.edu and capture the login credentials with wireshark, with HTTPS enabled by decrypting HTTPS traffic to and from freewifi.ewubd.edu.

Perform a TCP SYN Flood attack from the client VM to the web server with IP/MAC spoofing on/off, and identify the details of the attack from the server log, and identify the attacker from the server logs.

Preconfigure OCSP for immediate certificate revocation.

During the demonstration:
You will be given a domain name to configure DNS and HTTPS within 20 minutes as a group. Viva and Demonstration will be individual. The following checks will be performed to evaluate your work:
Forward and reverse nslookup to the given domain names.
Inspecting the Trust Center of the browser in the client VM and the server VM with no Sub-CA, and visual padlock on the browser while visiting the given sites.
Verification if http://domain.com is automatically redirected to https://domain.com.
Revocation of certificates with OCSP and verification of insecure connection upon certificate revocation.
Verification of the output of the command cat /etc/passwd on the server.
Verification of the output of the command cat /etc/hosts on the server and the client.
Ability to decrypt HTTPS and File Carving: Starting a wireshark capture, downloading the academic calendar PDF from https://www.ewubd.edu/academic-calendar and reconstructing the file from the capture with NetworkMiner or Wireshark.

Requirements:

- ☐ Configuration of Certification Authority AcmeCA with AcmeRootCA as the RootCA.
- ☐ Configuration of the SubCA as the AcmeSubCA.
- ☐ Configuration of the Web Server with Apache2 on a Linux Host.
- ☐ Configuration of multiple websites on a single server.
- ☐ DNS server configuration to resolve www.ewubdca.com, www.cnn.com, www.bbc.com. For both forward and reverse zones. DNS server should resolve multiple domains.
- ☐ DNS server configuration to resolve two subdomains:

  apply.ewubdca.com

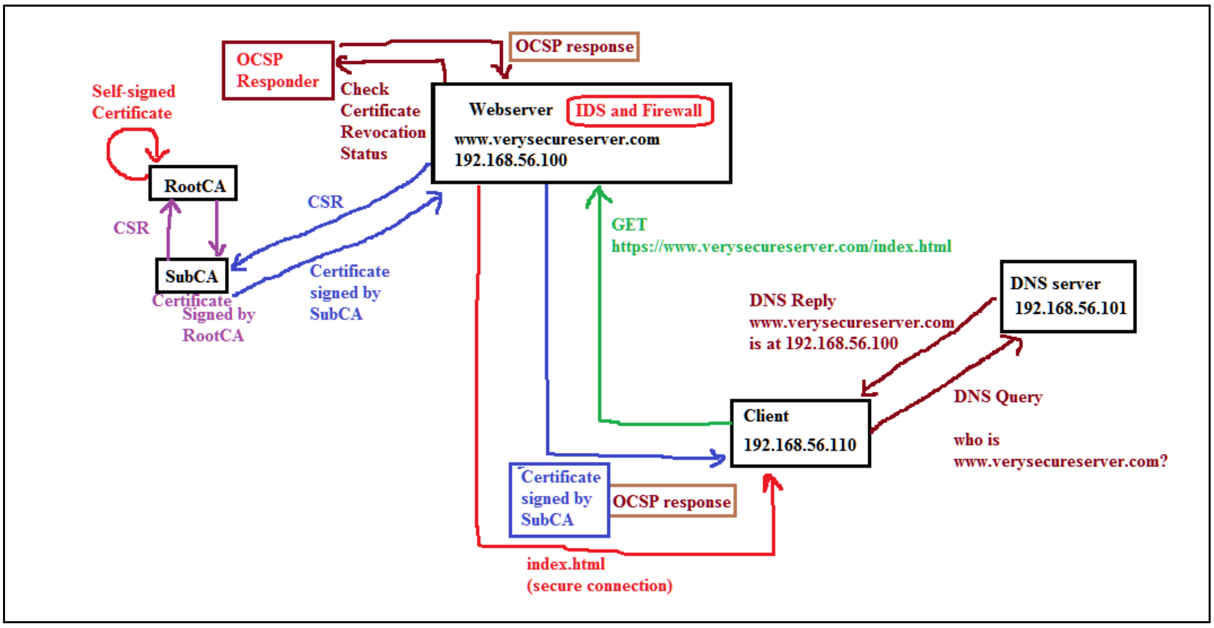
  www.ewubdca.com

- ☐ Firewall configuration to allow necessary ports (22, 53, 80, 443, 3000) only, deny all other ports.
- ☐ Installing and configuring OpenSSH to enable SSH to the server and the CA.
- ☐ Change the SSH default port from 22 to 3000.
- ☐ CSR Configuration and Generation for the www.ewuca.com and for any of its subdomains *..ewuca.com
- ☐ Create a webpage and place a form to take CSR from the visitors as text input, and include textboxes to take relevant information from the requester for Organizational Validation.
- ☐ Transfering the CSR to AcmeCA by SFTP/SCP/VM networking/CA Web-interface.
- ☐ Certification process (Verification and Certificate Generation from CSR).
- ☐ Transferring the certificate from AcmeCA to the server www.verysecureserver.com by SFTP/SCP/VM networking.
- ☐ Installation of the signed the SSL certificate in the server of www.verysecureserver.com
- ☐ Making the system trust Acme-RootCA (the certificate of the SubCA should not be imported into the client PC).
- ☐ Implementation of a simple file uploading page in the server.
- ☐ Automatically redirect all http:// traffic to https://
- ☐ Verifying the security of the connection by inspection (the padlock icon).
- ☐ Identify the TCP three-way-handshake and TLS four-way-handshake packets in Wireshark from another computer while connecting to https://www.verysecureserver.com
- ☐ Revoke the certificate issued to www.verysecureserver.com from the CA and distribute the first CRL.
- ☐ Verifying the revocation of previous certificate from the CRL (no padlock icon).
- ☐ Configuring IDS, and demonstrating a SYN flood attack and identifying the attacker from the log files.
- ☐ Block the attack by any means (e.g., blacklist the attacker's ip address in the firewall).
- ☐ Creating a Website called www.acmeca.com where the users can paste their CSRs and get a signed certificate ready to be downloaded.
- ☐ Configuring OCSP to manage certificates and CRLs.
- ☐ Revoke the certificate and show the padlock is gone.

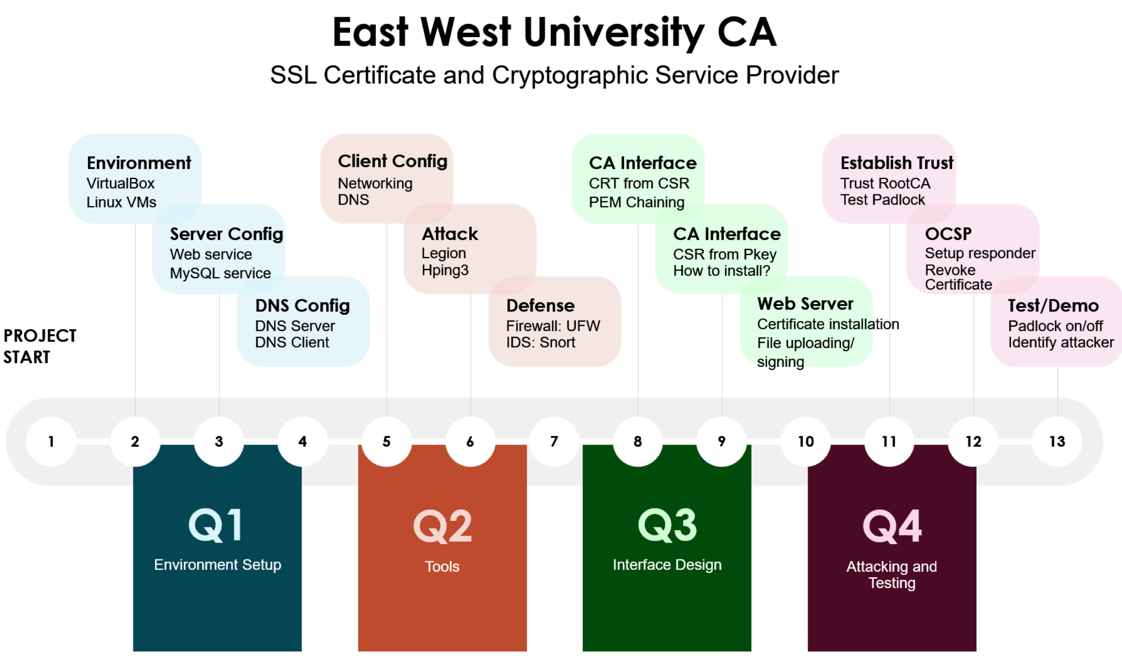
Task	**Marks**
DNS forward and reverse configuration with multiple domains and subdomains	
Webserver configuration to host websites on a single server	
Webserver configuration to host multiple websites on a single server	

Configuration of RootCA, SubCA Generate CSR and certificates for the given domains	
Generate wildcard certificates for the given subdomains	
Install the SSL certificates on the webserver	
Install the RootCA certificate in the client browser	
Firewall configuration	
SSH connection on port 3000	
IDS configuration: perform SYN Flood attack, block the attacker	
Web Interface for AcmeCA	
Configuring OCSP to manage certificates and CRLs.	

Network Setup:



Project workflow:



Reporting:

Submit a written tutorial in PDF format with necessary screenshots, instructions and commands, that can be followed to fulfill the aforementioned requirements.

Demonstration and viva will be taken after the Midterm exam.

Mini Project-2:
Activity: Criticism of Terms of Service (ToS), End User License Agreement (EULA), Privacy Policy fulfilling the legal requirements and the existing practices for a particular sector.
Means of delivery: Case studies with infographic/poster/prezi/video presentation.

Requirements:
Perform a thorough analysis of all the existing applicable laws and regulations/ directives/ guidelines/ frameworks on a particular field related to IT and Computer Science and Engineering.

For example, the Telecommunications sector, Telemedicine, Digital Marketing, Freelancing, Online and Mobile Financial services, Food delivery, Transportation, Entertainment, OTT Platforms, Social Media, News and other media, YouTube channels, Facebook pages, and so on.

Find existing interesting cases and present your criticisms. Use AI tools

Group mode: Groups of 3
Marks: 10% (10 out of 100)

Poster/Infographic Size: Four A4 size papers = One A2 size paper (420 x 594 mm)
Guidelines:

- How to Create a Research Poster
- Poster Session Tips

Prezi/Video content length: 300 seconds
Prezi Sample: https://prezi.com/i/s4uumcoec7rl/che-amylie-yulia-infographic/
https://prezi.com/i/ttbsyxz09mak/back-to-school-digital-shopping-habits-2019
https://prezi.com/u-zz9ydmygz2/infographic-report-prezi-template/

Tips:
In this project the students compare a specific IT business sector and compare/criticize their legal compliance with the applicable local and global laws. Students submit an infographic/poster/prezi/video describing the findings. Additionally, your content must tell an interesting story/fact/incident.

Please present the content in a captivating manner to retain the attention of the viewer. Don't make it boring!

AI Usage: The goal of the content will be to raise awareness among the students of your department and the university as a whole. The use of AI tools are recommended and the poster **must explain how AI was used in this project**. So please create your accounts and compare their findings and verify them.

Copy the Terms & Conditions (T&C) from different IT ventures, and paste them into AI, and chat with the T&C. Ask it about its compliance with the principles of data collection, Bangladesh Cyber Security Act of 2023, EU GDPR, and any other applicable laws. Present your findings.

Typical questions to be asked to the AI:
Legal aspects:
1. What data is collected?
2. How will the data be used?
3. What is the opt-out policy?
4. How will the collected data be stored?
5. How will accuracy of the data be maintained?
6. How will security and access to the data be maintained?
7. Who is the handler, processor, requester of the data?
8. Will the data be used again?
9. Is there any copyright/patent involved with the business?
10. Can I see my data?
11. What are you doing with my data?
12. What benefits am I getting?
13. What are the risks of using this service?
14. And so on.

Business Aspects:
1. Can you think of a business service that provides "Human-Driven AI-Assisted legal decision support and compliance checking" as a service?
2. Who will be your customer?
3. How big is the market in Bangladesh and abroad?
4. What is the level of legal compliance of such a new IT venture?

Mini Project-3: Ethical Decision Making in the field of IT/CSE and criticism and justification of actions/stance as per ethical frameworks

Activity: Case studies, Group debate and Report Writing
- Presenting an ethical dilemma in decision making for a real(-istic) case in the field of IT/CSE
  - Identifying possible/probable decisions
  - Analyzing each the decision
  - Justification of the chosen decision
- Case report and Defense Presentation
- Opposition Report and Presentation criticizing the opponents' decision
- Rebuttal and open discussion/debate

CO	Description	Case Report	Defense Presentation	Opposition Report	Opposition Presentation	Rebuttal	CO Total
	Marks	**5**	**2**	**3**	**3**	**2**	**15**
CO4	**Apply** and **appreciate** the professional	**C: 2** **A: 3**					**5**

	codes of conduct and ethical frameworks for developing networked systems.						
CO5	**Communicate** effectively and **write** effective reports for modern networked systems from cybersecurity, legal and ethical perspectives		**P: 2**	**A:3**			**5**
CO6	**Recognize** the need for and **adapt** to the broadest context of technological and legal changes for developing modern networked systems.				**A: 3**	**P: 2**	**5**

The Defense Report should contain (Limit 4 pages)

- ☐ Details of a case/scenario that involves an ethical dilemma and requires decision making in a ethical manner
- ☐ Identify the dilemma clearly and the possible/probable decisions
- ☐ Justification of the chosen decision based on the Ethical Theories following the steps to ethical decision making.
    - ☐ Brainstorming Phase
    - ☐ Analysis Phase
    - ☐ Decision Phase

The following will be the drill for debate session:

- ➢ ***The defending group will have 6 minutes to complete their presentation.***
- ➢ ***Then the opponent group will have 3 minutes to present the opposition.***
- ➢ ***Then the defending group will have 1 minute to present for the rebuttal.***
- ➢ ***Open discussion/debate on the decision will follow for 2 minutes.***

The Defending group shall present their work for 6 minutes. This could be 3 x 2 minute presentations, or the group leader may present the whole presentation.

The defense presentation (6 minutes) and the report (limit: 4 pages) should highlight:

- ☐ The presented scenario and the probable decisions
- ☐ The ethical dilemma associated with each of the decisions
- ☐ Analysis of each of the decisions showing every steps of the decision making process (both brainstorming and analysis phase) [*should be emphasized*]
- ☐ Responsibility of you as a decision maker and the rights of the stakeholders
- ☐ Justification of the chosen decision based on the ethical theories [**most emphasis should be given**]

The opposition report (limit: 2 pages) and presentation (3 minutes) should highlight

- ☐ Summary of the opponents' scenario and ethical dilemma
- ☐ Strongest aspect of the opponents' work
- ☐ Weakest aspect of the opponents' work
- ☐ Suggestions/Criticisms to the opponents' decision [**most emphasis should be given**]

The defending group shall refute the opponents' criticisms for 1 minute, followed by an open discussion/debate session for 2 minutes.

Marks distribution of the MP-3 will be as follows:

Activity	Mark
Project Report	5
Defense Presentation	2
Opposition Report	3
Opposition Presentation	3
Rebuttal/Open Discussion	2
Total	15

Dates and Deadlines:
23:59 Saturday Jun 7, 2024 11:49 PM - Deadline for submitting Defense Report and slides
08:00 Saturday Jun 9, 2024 8:00 AM - Deadline for submitting Opposition Report
(Slides not required for opposition)
09:00 Sunday Jun 9, 2024 9:00 AM - Defense and Debate Session

MP-3 Instructions for Spring 2024

https://docs.google.com/document/d/1K3CmD6WayoIiGxiAqPdCGSDTr0gwGA7H6LRVwxP2JRY/edit?usp=sharing

Suggested Topics

- Self-driving cars (The Moral Machine)
- Use of machine learning for adversarial purpose (Uyghur Detection Dataset)
- Social Rating System
- Limits to Ethical Hacking
- Trustworthiness of AI

  More topics could be found in: [Ethics of artificial intelligence - Wikipedia]
  Chapter 9 of the Book: A Gift of Fire by Sara Baase.

Resources for the ethical dilemma related to self-driving cars:

Links:

Moral Machine
https://www.moralmachine.net/
The Moral Machine experiment | Nature
https://www.nature.com/articles/s41586-018-0637-6
Moral Machine - Wikipedia
https://en.wikipedia.org/wiki/Moral_Machine
Why the moral machine is a monster [PDF]
https://robots.law.miami.edu/2019/wp-content/uploads/2019/03/MoralMachineMonster.pdf

The ethical dilemma of self-driving cars - Patrick Lin
https://www.youtube.com/watch?v=ixIoDYVfKA0
The Social Dilemma Of Driverless Cars | Iyad Rahwan | TEDxCambridge
https://www.youtube.com/watch?v=nhCh1pBsS80
The Trolley Problem in Real Life
https://www.youtube.com/watch?v=1sl5KJ69qiA

Resources for Trustworthiness of AI:

Trustworthy AI and the foundations of AI systems - Ericsson
https://www.ericsson.com/en/blog/2020/12/trustworthy-ai
AI – Ethics inside? - Ericsson
https://www.ericsson.com/en/reports-and-papers/industrylab/reports/ai-ethics
AI bias and human rights: Why ethical AI matters - Ericsson
https://www.ericsson.com/en/blog/2021/11/ai-bias-what-is-it
Trustworthy AI | IBM
https://www.ibm.com/watson/trustworthy-ai
AI Ethics | IBM
https://www.ibm.com/artificial-intelligence/ethics

Steps to Ethical Decision Making (by *Sara Baase*):

Textbook: S. Baase, ***A Gift of Fire: Social, Legal, And Ethical Issues For Computing Technology*** *(4th edition)*, Boston, MA, United States: Prentice Hall, 2012.

Reference:

A. Adams and R. J. McCrindle, *Pandora's box: Social and professional issues of the information age*. Chichester, England: Wiley, John & Sons, 2008.

J. M. Kizza, *Ethical and social issues in the information age, 5th ed.* London: Springer-Verlag New York, 2013.

Brainstorming phase:

- List all the people and organizations affected. (They are the stakeholders.)
- List risks, issues, problems, consequences.
- List benefits. Identify who gets each benefit.
- In cases where there is not a simple yes or no decision, but rather one has to choose some action, list possible actions.

Analysis phase:

- Identify responsibilities of the decision maker. (Consider responsibilities of both general ethics and professional ethics.)
- Identify the rights of stakeholders. (It might be helpful to clarify whether they are negative or positive rights)
- Consider the impact of the action options on the stakeholders.
- Analyze consequences, risks, benefits, harms, and costs for each action considered.
- Consider Kant's, Mill's, and Rawls' approaches.
- Then, categorize each potential action or response as ethically obligatory, ethically prohibited, or ethically acceptable.

Decision Phase:

If there are several ethically acceptable options, select an option by considering the ethical merits of each, courtesy to others, practicality, self-interest, personal preferences, and so on. (In such a case, plan a sequence of actions, depending on the response to each.)